

TERMS OF REFERENCE (TOR)

MANAGED SECURITY OPERATIONS CENTER (SOC) SERVICES PT SENTOSA ABADI FINANSIAL

Document Reference: TOR/SA/IT-SEC/2026-014

Issue Date: 4 May 2026

Proposal Submission Deadline: 30 May 2026

1. BACKGROUND

PT Sentosa Abadi Finansial ("Sentosa") is a digital lending and payments company licensed and supervised by Otoritas Jasa Keuangan (OJK). Sentosa operates a customer-facing mobile application and a core lending platform that together process more than 120,000 transactions per day. As transaction volume and regulatory scrutiny grow, Sentosa intends to engage a qualified managed security services provider to operate a 24/7 Security Operations Center on its behalf.

This Terms of Reference sets out the scope, requirements, and submission rules for prospective providers.

2. OBJECTIVE

The objective of this engagement is to obtain continuous security monitoring, threat detection, and incident response for Sentosa's production environment, delivered to defined service levels and aligned with OJK regulations and the ISO/IEC 27001 standard.

3. CONTRACT DURATION

The initial contract term shall be twelve (12) months, commencing on the agreed service-commencement date, with an option to extend for two further periods of twelve (12) months each, subject to satisfactory performance.

4. SCOPE OF REQUIRED SERVICES

The selected provider shall deliver the following. Items marked [MANDATORY] are pass/fail requirements; a proposal that does not address a mandatory item may be disqualified.

R1. [MANDATORY] 24x7x365 security monitoring of Sentosa's cloud and on-premise production environment from a staffed Security Operations Center.

R2. [MANDATORY] Deployment, tuning, and ongoing management of a Security Information and Event Management (SIEM) platform, including log onboarding for all in-scope systems.

R3. [MANDATORY] Incident response with documented service levels: acknowledgement of CRITICAL incidents within 15 minutes and commencement of containment within 30 minutes, 24 hours a day.

R4. [MANDATORY] Quarterly vulnerability assessment and penetration testing of Sentosa's public-facing applications, with remediation tracking.

R5. Monthly executive security report and a quarterly service-review meeting with Sentosa management.

R6. [MANDATORY] Demonstrable support for Sentosa's regulatory compliance, specifically OJK security requirements for financial technology operators and the ISO/IEC 27001 control framework.

R7. [MANDATORY] All customer and security log data must be stored and processed within data-center facilities located in Indonesia (data residency).

R8. Integration of at least one commercial or government threat-intelligence feed into the monitoring platform.

R9. Security-awareness training for Sentosa staff, delivered at least twice per contract year.

R10. Service transition and onboarding completed within eight (8) weeks of contract signature, with a documented transition plan.

R11. A named, dedicated account manager and a documented escalation matrix.

R12. [MANDATORY] The provider must demonstrate at least three (3) years of experience delivering comparable managed SOC services, supported by at least two client references in the financial sector.

5. PROPOSAL CONTENT REQUIREMENTS

Each proposal MUST contain, at minimum:

- a. An executive summary.
- b. A description of the provider's company, including relevant certifications.
- c. A scope of work that addresses every requirement R1-R12 above.
- d. The proposed methodology and service-delivery approach.
- e. A project timeline covering transition and steady-state operations, with dated milestones.
- f. The proposed team, including roles, named key personnel, and certifications.
- g. A complete and itemised price schedule, stating one-time transition fees, recurring monthly fees, applicable taxes, and the total 12-month contract value in Indonesian Rupiah.
- h. A clear statement of all assumptions, dependencies, and exclusions on which the proposal and price are based.
- i. Relevant client references and case studies.

6. EVALUATION CRITERIA

Proposals will be evaluated on: compliance with mandatory requirements (pass/ fail); technical approach and methodology; relevant experience and references; team qualifications; commercial competitiveness and clarity of pricing; and clarity of assumptions and risk allocation.

7. SUBMISSION

Proposals must be submitted in PDF format by 30 May 2026. Incomplete proposals, or proposals that omit the price schedule or the statement of assumptions, will be considered non-responsive.

— END OF TERMS OF REFERENCE —